

Cybersecurity Engineering Internship Report

Phase 2: Automated Infrastructure Mapping, Directory Auditing & Security Assessments

Name: Ashfaque Ali Channa

Focus Area: Black-Box Footprinting, Attack Surface Discovery & Configuration Verification

1. Executive Summary

Phase 2 deployed advanced security assessment frameworks to perform deep, multi-layered environment mapping. By conducting systematic web service fingerprinting, open port inventory validation, and structured path fuzzing, hidden data entry surfaces and configuration gaps were surfaced for proactive remediation.

2. Enterprise Target Deployment Initialization

To test corporate deployment auditing, an industry-standard sandbox application environment—**OWASP WebGoat**—was initialized as the primary discovery target.

```
WebGoat

2026-06-07T04:55:39.506-04:00 INFO 9935 [main] org.owasp.webgoat.server.StartWebGoat : No active profile set, falling back to 1 default profile: "default"
2026-06-07T04:55:40.717-04:00 INFO 9935 [main] .s.d.r.c.RepositoryConfigurationDelegate : Bootstrapping Spring Data JPA repositories in DEFAULT mode.
2026-06-07T04:55:40.799-04:00 INFO 9935 [main] .s.d.r.c.RepositoryConfigurationDelegate : Finished Spring Data repository scanning in 81 ms. Found 2 JPA repository interfaces.
2026-06-07T04:55:41.224-04:00 WARN 9935 [main] io.undertow.websockets.jsr : UT20010: Buffer pool was not set on websocketDeploymentInfo, the default pool will be used
2026-06-07T04:55:41.230-04:00 INFO 9935 [main] io.undertow.servlet : Initializing Spring embedded WebApplicationContext
2026-06-07T04:55:41.231-04:00 INFO 9935 [main] w.s.c.ServletWebServerApplicationContext : Root WebApplicationContext: initialization completed in 1623 ms
2026-06-07T04:55:41.827-04:00 INFO 9935 [main] o.f.c.internal.license.VersionPrinter : Flyway Community Edition 9.16.3 by Redgate
2026-06-07T04:55:41.828-04:00 INFO 9935 [main] o.f.c.internal.license.VersionPrinter : See release notes here: https://rd.gt/4100UMi
2026-06-07T04:55:41.829-04:00 INFO 9935 [main] o.f.c.internal.license.VersionPrinter : Database: jdbc:hsqldb:file://www/kali/.webgoat-2023.8/webgoat (HSQL Database Engine 2.7)
2026-06-07T04:55:41.869-04:00 INFO 9935 [main] o.f.c.i.database.base.BaseDatabaseType : Flyway upgrade recommended: HSQLDB 2.7 is newer than this version of Flyway and support has not been tested. The latest supported version of HSQLDB is 2.6.
2026-06-07T04:55:42.025-04:00 INFO 9935 [main] o.f.c.core.internal.command.DbValidate : Successfully validated 4 migrations (execution time 00:00.064s)
2026-06-07T04:55:42.052-04:00 INFO 9935 [main] o.f.c.core.internal.command.DbMigrate : Current version of schema "container": 3
2026-06-07T04:55:42.059-04:00 INFO 9935 [main] o.f.c.core.internal.command.DbMigrate : Schema "container" is up to date. No migration necessary.
2026-06-07T04:55:42.127-04:00 INFO 9935 [main] o.h.bernate.jpa.internal.util.LogHelper : HH0000204: Processing PersistenceUnitInfo [name: default]
2026-06-07T04:55:42.163-04:00 INFO 9935 [main] o.s.o.j.p.SpringPersistenceUnitInfo : No loadTimeWeaver setup; ignoring JPA class transformer
2026-06-07T04:55:42.214-04:00 WARN 9935 [main] org.hibernate.orm.deprecation : HH00000025: HSQLDialect does not need to be specified explicitly using 'hibernate.dialect' (remove the property setting and it will be selected by default)
2026-06-07T04:55:42.786-04:00 INFO 9935 [main] o.h.e.t.j.p.i.JtaPlatformInitiator : HH0000489: No JTA platform available (set 'hibernate.transaction.jta-platform' to enable JTA platform integration)
2026-06-07T04:55:42.787-04:00 INFO 9935 [main] j.LocalContainerEntityManagerFactoryBean : Initialized JPA EntityManagerFactory for persistence unit 'default'
2026-06-07T04:55:43.339-04:00 INFO 9935 [main] o.o.w.lessons.logging.LogBleedingTask : Password for admin: OGNKNW3mZ7ATYwFkNS00vTQ4Lg3YtCzFhYj157jF1ZGZm
2026-06-07T04:55:43.661-04:00 WARN 9935 [main] o.o.w.c.lessons.CourseConfiguration : Lesson: webgoat.title has no endpoints, is this intentionally?
2026-06-07T04:55:46.924-04:00 INFO 9935 [main] o.s.b.a.e.web.EndpointLinksResolver : Exposing 3 endpoint(s) beneath base path '/actuator'
2026-06-07T04:55:46.986-04:00 INFO 9935 [main] o.s.s.web.DefaultSecurityFilterChain : Will secure any request with [org.springframework.security.web.session.DisableEncodeUrlFilter@67a0ff25, org.springframework.security.web.authentication.logout.LogoutFilter@4bbc21bd, org.springframework.security.oauth2.client.web.OAuth2AuthorizationRequestRedirectFilter@4dd12dbb, org.springframework.security.web.servletapi.SecurityContextHolderAwareRequestFilter@6cebe36, org.springframework.security.web.authentication.AnonymousAuthenticationFilter@166e5add, org.springframework.security.web.access.ExceptionTranslationFilter@72a2688d, org.springframework.security.web.access.intercept.AuthorizationFilter@db85b399]
2026-06-07T04:55:49.453-04:00 [main] WARN FileUtil : Native subprocess control requires open access to the JDK 10 subsystem
2026-06-07T04:55:49.453-04:00 [main] WARN FileUtil : Native subprocess control requires open access to the JDK 10 subsystem
2026-06-07T04:55:54.153-04:00 WARN 9935 [main] io.thymeleaf.check-template-location-false : Cannot find template location: classpath:/templates/ (please add some templates, check your Thymeleaf configuration, or set spring.g.thymeleaf.check-template-location=false)
2026-06-07T04:55:54.180-04:00 INFO 9935 [main] io.undertow : Starting server: Undertow - 2.3.18.Final
2026-06-07T04:55:54.186-04:00 INFO 9935 [main] o.s.b.w.e.undertow.UndertowWebServer : Undertow started on port(s) 8080 (http) with context path '/WebGoat'
2026-06-07T04:55:54.193-04:00 INFO 9935 [main] org.owasp.webgoat.server.StartWebGoat : Started StartWebGoat in 14.715 seconds (process running for 41.866)
2026-06-07T04:55:54.203-04:00 WARN 9935 [main] org.owasp.webgoat.server.StartWebGoat : Please browse to http://127.0.0.1:8080/WebGoat to start using WebGoat ...
2026-06-07T04:58:46.388-04:00 INFO 9935 [XNIO-2 task-2] io.undertow.servlet : Initializing Spring DispatcherServlet 'dispatcherServlet'
2026-06-07T04:58:46.620-04:00 INFO 9935 [XNIO-2 task-2] o.s.web.servlet.DispatcherServlet : Initializing Servlet 'dispatcherServlet'
2026-06-07T04:58:47.484-04:00 INFO 9935 [XNIO-2 task-2] o.s.web.servlet.DispatcherServlet : Completed initialization in 847 ms
```

3. Automated Port Footprinting & Service Discovery

A rigorous reconnaissance script was executed via **Nmap** to audit active network binds, map service variations, and flags running on unmapped ports.

```
kali@kali: ~  
$ nmap -p 8080 -v localhost  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-07 04:56 -0400  
Nmap scan report for localhost (127.0.0.1)  
Host is up (0.00016s latency).  
Other addresses for localhost (not scanned): ::1  
  
PORT      STATE SERVICE      VERSION  
8080/tcp  open  http-proxy  
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
```

4. Web Directory Fuzzing & Endpoint Enumeration

Using **Gobuster**, automated wordlist path expansion routines were executed against the application target root. This uncovered hidden administrative, registration, and entry points that traditional web crawlers miss.

```
kali@kali: ~  
$ gobuster dir -u http://localhost:8080/WebGoat -w /usr/share/wordlists/dirb/common.txt -b 302  
  
Gobuster v3.8.2  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)  
  
[+] Url: http://localhost:8080/WebGoat  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/wordlists/dirb/common.txt  
[+] Negative Status codes: 302  
[+] User Agent: gobuster/3.8.2  
[+] Timeout: 10s  
  
Starting gobuster in directory enumeration mode  
  
meta-inf (Status: 404) [Size: 0]  
META-INF (Status: 404) [Size: 0]  
login (Status: 200) [Size: 1929]  
registration (Status: 200) [Size: 4190]  
web-inf (Status: 404) [Size: 0]  
WEB-INF (Status: 404) [Size: 0]  
Progress: 4613 / 4613 (100.00%)  
  
Finished
```

5. Broad Vulnerability Scanning: Nikto & OWASP ZAP

Comprehensive vulnerability scanners were run against the target assets to identify outdated software banners, missing anti-framing defenses, and cross-site scripting vulnerabilities.

```
kali@kali: ~  
$ nano csrf_exploit.html  
$ mkdir csrf-lab 06 cd csrf-lab  
mkdir: cannot create directory 'csrf-lab': File exists  
$ mkdir csrf-lab 06 cd csrf-lab  
mkdir: cannot create directory 'csrf-lab': File exists  
$ cd csrf-lab  
$ nano server.js  
$ node server.js  
[+] Vulnerable Server running on http://localhost:3000  
^C  
$ cd csrf-lab  
$ nano server.js  
$ node server.js  
[+] Hardened Server running on http://localhost:3000
```

Secure Connection Failed
An error occurred during a connection to www.google.com. The SSL peer certificate
expired on 2026-06-07 04:56:00.
The page may have been moved, but the server did not return the correct status code.
Please check the website's status to learn the reason for this problem.


```
kali@kali: ~  
$ nikto -h http://localhost:3000  
- Nikto v2.6.0  
  
+ Target IP: 127.0.0.1  
+ Target Hostname: localhost  
+ Target Port: 3000  
+ Platform: Unknown  
+ Start Time: 2026-06-08 07:33:10 (GMT-4)  
  
+ Server: No banner retrieved  
+ ERROR: Failed to check for updates: 403  
+ [999986] /: Retrieved x-powered-by header: Express.  
+ No CGI Directories Found (use "-C all" to force check all possible dirs). CGI tests skipped.  
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy  
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security  
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy  
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options  
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ 7964 requests: 16 errors and 6 items reported on the remote host  
+ End Time: 2026-06-08 07:39:30 (GMT-4) (372 seconds)  
  
+ 1 host(s) tested
```

7. Phase 2 Conclusion

Phase 2 successfully mapped our complete attack surface, providing the precise tracking metrics needed to drive targeted defensive patches across our infrastructure.